ESPECIFICACIÓN DE PRODUCTO (PRD)

Plataforma e-commerce — Suplementos, nutrición deportiva y bienestar

Versión 2.0 — Documento de producto. No incluye presupuesto ni cronograma comercial (ver Propuesta Comercial v2.0 aparte).

1. Resumen ejecutivo

Se propone desarrollar una plataforma e-commerce para venta de suplementos, nutrición deportiva y bienestar, con panel administrativo que permita controlar catálogo, inventario, pedidos, clientes, promociones, contenido y reportes.

Este documento define QUÉ se construye y bajo qué reglas. Deliberadamente no incluye estimaciones de tiempo ni presupuesto: esos términos viven en la Propuesta Comercial y deben negociarse por separado, para que un cambio de alcance no obligue a renegociar precio y viceversa.

Al ser un negocio de suplementos, el cumplimiento regulatorio (sección 5) y la protección de datos personales no son opcionales ni de fase posterior: condicionan el modelo de datos y el flujo de publicación de catálogo desde el día uno.

2. Objetivos de negocio y métricas de éxito

2.1 Objetivos

- Vender productos en línea 24/7.
- Reducir al mínimo los pasos del checkout.
- Centralizar inventario, pedidos y clientes.
- Permitir promociones, cupones y campañas.
- Automatizar confirmaciones y seguimiento por correo/WhatsApp.
- Generar reportes comerciales y operativos.
- Preparar la plataforma para crecer a múltiples sucursales.
- Mantener trazabilidad de cambios administrativos.
- Aplicar controles de seguridad desde el diseño.
- Operar dentro del marco regulatorio aplicable a suplementos y datos personales.

2.2 Métricas de éxito (a validar con el negocio)

> *Los valores siguientes son marcadores de referencia de la industria, no compromisos. Deben reemplazarse con cifras reales acordadas con el negocio antes de usarse como criterio de éxito.*

Métrica	Referencia inicial	Fuente / notas
Tasa de conversión	1%–3%	Rango típico e-commerce de nicho; validar contra benchmark del sector suplementos
Tasa de abandono de carrito	< 70%	Promedio de industria ~70%; objetivo es no superarlo
LCP (carga de página)	< 2.5 s	Umbral 'bueno' de Core Web Vitals
Disponibilidad (uptime)	99.5%	A confirmar según SLA del hosting elegido
Valor promedio de pedido (AOV)	[DEFINIR]	Requiere dato histórico del negocio o meta comercial

3. Alcance funcional

3.1 Sitio público

- Inicio con banners, categorías, promociones y productos destacados.
- Buscador global con autocompletado.
- Categorías y filtros por marca, objetivo, presentación, precio y disponibilidad.
- Ficha de producto con fotografías, descripción, variantes, precio, stock, promociones y recomendaciones.
- Carrito persistente.
- Checkout como invitado y para clientes registrados.
- Página de contacto, preguntas frecuentes, políticas, envíos y devoluciones.
- Blog/contenido para SEO.

3.2 Cuenta del cliente

- Registro e inicio de sesión.
- Recuperación de contraseña.
- Direcciones de envío.
- Historial y detalle de pedidos.
- Favoritos.
- Avisos de disponibilidad.
- Perfil y preferencias, incluyendo gestión de consentimientos de datos personales.
- Programa de puntos (fase posterior, no MVP).

3.3 Checkout y pagos

- Resumen de productos y cantidades.
- Cálculo de envío.
- Aplicación de cupones.
- Selección de método de pago.
- Confirmación de pedido.
- Estados: pendiente, pagado, preparando, enviado, entregado, cancelado y reembolsado.
- Webhooks para confirmar pagos de forma segura.
- Regla dura: nunca marcar un pedido como pagado únicamente por una respuesta del navegador del cliente; solo por webhook verificado del proveedor.

3.4 Administración

- Dashboard con ventas, pedidos, productos, stock y clientes.
- CRUD de productos, categorías, marcas y variantes, incluyendo estado de revisión regulatoria (ver sección 5).
- Gestión de imágenes.
- Inventario por producto/variante.
- Movimientos de inventario.
- Promociones y cupones.
- Gestión de pedidos.
- Clientes.
- Contenido del sitio.
- Reportes y exportaciones.
- Usuarios administrativos y permisos.
- Bitácora/auditoría de acciones administrativas.

3.5 Inventario

- SKU único por variante.
- Stock disponible, reservado y mínimo.
- Entradas, salidas, ajustes y devoluciones con historial de movimientos.
- Alertas de bajo inventario.
- Lotes y caducidades: obligatorio para cualquier producto consumible, no opcional (ver sección 5).
- Soporte futuro para múltiples almacenes/sucursales.

3.6 Marketing y conversión

- Cupones por porcentaje o cantidad.
- Promociones por producto/categoría.
- Productos relacionados y frecuentemente comprados juntos.
- Recuperación de carrito abandonado.
- Newsletter.
- Reseñas moderadas.
- Banners programables y landing pages para campañas.

3.7 Comunicación

- Correo de confirmación de pedido, pago, cambio de estado y envío.
- Contacto por WhatsApp como canal de apoyo (no sustituto del flujo de compra).
- Plantillas editables para mensajes.

4. Catálogo y estructura comercial

Cada producto debe manejar, como mínimo:

- Nombre comercial, marca, categoría y subcategoría.
- SKU y código de barras opcional.
- Descripción corta y larga.
- Galería de imágenes.
- Variantes: sabor, tamaño, presentación, etc.
- Precio normal, precio promocional y costo interno (protegido, no expuesto al cliente).
- Stock y stock mínimo.
- Peso y dimensiones para envío.
- Estado comercial: borrador, activo, agotado, oculto.
- Información de lote/caducidad (obligatoria en productos consumibles).
- SEO: slug, título y meta descripción.
- **Estado de revisión regulatoria: pendiente / aprobado / rechazado — campo obligatorio que bloquea la publicación (ver sección 5).**

Nota: el sistema de categorías no incluye ni permite crear categorías de esteroides, SARMs u hormonas de crecimiento (ver sección 5.0). Esto es una restricción de diseño, no solo una regla de moderación de contenido.

5. Cumplimiento regulatorio y protección de datos

> *Esta sección es un bloqueante de diseño, no una nota legal aparte. Debe resolverse antes de cargar catálogo real en producción.*

5.0 Exclusión de alcance — sustancias controladas

Esta plataforma se diseña exclusivamente para suplementos alimenticios y productos de nutrición/bienestar de venta libre. Quedan excluidos por diseño, y no deben poder cargarse en el catálogo bajo ninguna categoría:

- Esteroides anabólico-androgénicos.
- SARMs (moduladores selectivos del receptor de andrógenos).
- Hormonas de crecimiento (somatropina/HGH) y péptidos hormonales.
- Cualquier sustancia de venta controlada o exclusiva con receta médica bajo la Ley General de Salud.

Esta exclusión se implementa como control técnico, no solo como política: el sistema de categorías (sección 4) no incluye estas familias de producto, y el campo 'estado de revisión regulatoria' bloquea por categoría — no solo por producto individual — cualquier intento de cargar un ítem de estas familias, con o sin nombre comercial distinto. Si en algún momento el negocio quisiera comercializar productos de este tipo, eso requiere primero una revisión legal independiente (licencias, manejo de sustancias controladas, verificación de receta) fuera del alcance de este documento, y no debe tratarse como una extensión menor del catálogo existente.

5.1 Regulación sanitaria de suplementos (México — COFEPRIS)

- Ningún producto se publica sin verificar si requiere aviso de funcionamiento, registro sanitario o permiso equivalente.
- Prohibido publicar declaraciones de propiedades terapéuticas o médicas no autorizadas (ej. 'cura', 'trata', 'aumenta testosterona') sin sustento regulatorio verificado.
- Productos de riesgo (esteroides, SARMs, hormonas, inyectables, sustancias controladas) quedan bloqueados por defecto y requieren aprobación legal explícita, documentada por producto, antes de integrarse al catálogo.
- El campo 'estado de revisión regulatoria' (sección 4) implementa este control a nivel de flujo: sin aprobación, el producto no puede pasar a estado 'activo'.

5.2 Protección de datos personales (LFPDPPP)

- Aviso de privacidad accesible antes de cualquier captura de datos personales.
- Consentimiento explícito y registrado para tratamiento de datos, con capacidad de revocarlo.
- Mecanismo funcional para derechos ARCO (acceso, rectificación, cancelación, oposición).
- Cifrado de datos personales sensibles en tránsito y en reposo.

5.3 Alcance de responsabilidad

Esta especificación describe controles técnicos. No sustituye asesoría legal/regulatoria específica del negocio; se recomienda revisión por un profesional en regulación sanitaria antes de la primera publicación de catálogo.

6. Arquitectura tecnológica

Capa	Tecnología	Motivo / riesgo a considerar
Frontend	Next.js + React + TypeScript	Rendimiento, SEO y ecosistema maduro
UI	Tailwind CSS + componentes reutilizables	Velocidad y consistencia visual
Backend/DB	Supabase + PostgreSQL	Auth, DB, Storage; riesgo: RLS se vuelve compleja de mantener con roles granulares en fases avanzadas
Hosting	Vercel o equivalente	Deploy y CDN; riesgo: vendor lock-in — mitigar con backups exportables y esquema documentado en DATABASE.md
Pagos	Mercado Pago u otro proveedor	Checkout y webhooks; tokenización evita que la plataforma maneje datos de tarjeta directamente
Correo	Resend u otro transaccional	Correos automatizados
WhatsApp	WhatsApp Business API	Atención y notificaciones

Analytics	GA4 + eventos propios	Medición de conversión
Monitoreo	Sentry	Errores y rendimiento
Repositorio	GitHub	Control de versiones y CI/CD

7. Modelo de datos

Tablas principales: users/profiles, roles, products, product_variants, categories, brands, product_images, inventory, inventory_movements, inventory_lots, carts, cart_items, orders, order_items, payments, shipments, addresses, coupons, promotions, promotion_products, reviews, wishlists, loyalty_transactions, notifications, abandoned_carts, admin_audit_logs, site_content, branches.

Tablas adicionales requeridas por la sección 5:

- product_regulatory_status — historial de revisión regulatoria por producto, con responsable y fecha de aprobación.
- privacy_consents — registro de consentimientos de datos personales por usuario, con fecha, versión de aviso de privacidad y estado (otorgado/revocado).

Los datos administrativos y financieros no deben quedar expuestos al cliente mediante consultas directas. Se implementan políticas RLS y validaciones de servidor en cada tabla sensible.

8. Seguridad

- Autenticación segura y recuperación de cuenta.
- Row Level Security (RLS) en Supabase para toda tabla con datos de cliente o financieros.
- Roles y permisos por función administrativa.
- Validación de datos en servidor, no solo en cliente.
- Verificación criptográfica de webhooks de pago (firma del proveedor), no solo el código de respuesta HTTP.
- Rate limiting en endpoints sensibles — valor inicial propuesto: máx. 5 intentos de login por 15 minutos por IP/usuario; ajustar según proveedor de hosting.
- Auditoría de acciones administrativas (quién, qué, cuándo).
- Backups con objetivos explícitos — propuesta inicial: RPO 24 h, RTO 4 h; validar contra capacidad real del proveedor de hosting.
- Secretos únicamente mediante variables de entorno, nunca en el repositorio.
- Alcance PCI: la plataforma no almacena ni procesa datos completos de tarjeta; el flujo de pago se delega vía tokenización al proveedor, lo que reduce el alcance a SAQ A o equivalente — confirmar con el proveedor de pago elegido.
- Logs sin contraseñas, tokens ni información personal sensible.

9. Accesibilidad, SEO y rendimiento

- Estándar mínimo de accesibilidad: WCAG 2.1 nivel AA.
- URLs limpias y amigables; metadatos por producto y categoría.
- Sitemap, robots.txt y Schema.org para productos.
- Optimización de imágenes y carga diferida.
- Core Web Vitals dentro de umbrales 'buenos' (ver sección 2.2).
- Diseño mobile-first.

10. Experiencia de usuario

Principio central: comprar debe requerir la menor cantidad de decisiones y pantallas posibles. En móvil, el usuario debe poder buscar → seleccionar → agregar → pagar sin navegación innecesaria.

- Botón de compra visible.
- Información de stock clara.
- Costo de envío visible antes de pagar.
- Checkout corto.
- Persistencia del carrito.
- Mensajes claros ante errores.
- WhatsApp como canal de apoyo, no como sustituto obligatorio del e-commerce.

11. IA como ventaja competitiva (fase posterior)

La IA no es núcleo del MVP. Se incorpora después de estabilizar ventas, datos e inventario.

- Asistente de compra que filtre productos por objetivo y preferencias.
- Generación asistida de descripciones SEO (sujeta a revisión regulatoria antes de publicar, ver sección 5).
- Recomendaciones basadas en compras.
- Detección de productos con baja rotación y anomalías de inventario.
- Resumen automático de ventas.
- Asistente interno para consultar pedidos, stock y métricas.
- Generación de campañas y textos publicitarios con aprobación humana obligatoria.

12. Riesgos y supuestos

Riesgo	Probabilidad	Impacto	Mitigación
Desarrollador único (bus factor)	Alta	Alto	Documentación viva (PROJECT_STATUS.md, DATABASE.md, SECURITY.md); code review externo antes de producción
Retraso por revisión regulatoria tardía	Media	Alto	Resolver sección 5 antes de cargar catálogo real, no en paralelo al desarrollo
Vendor lock-in (Supabase/Vercel)	Media	Medio	Esquema documentado, backups exportables, evitar funciones propietarias no estándar donde sea posible
Deuda técnica por desarrollo acelerado con IA ('vibecoding')	Alta	Medio	Desarrollo por módulos verificables, pruebas después de cada módulo, sin generar el sistema completo en una sola instrucción
Errores en integración de pagos por pruebas insuficientes	Media	Alto	Pruebas de integración exhaustivas en sandbox del proveedor antes de producción; nunca confiar solo en respuesta del navegador
RLS mal configurada expone datos administrativos	Media	Alto	Pruebas específicas de acceso no autorizado por rol antes de cada release

13. Criterios de aceptación del MVP

- Un visitante puede encontrar un producto y agregarlo al carrito.

- El usuario puede completar un pedido.
- El pago se confirma mediante el proveedor y webhook verificado criptográficamente.
- El pedido queda registrado correctamente y el inventario se actualiza de forma consistente.
- El administrador puede cambiar el estado del pedido.
- El cliente recibe confirmaciones por correo.
- Las rutas administrativas están protegidas y las políticas RLS impiden acceso indebido (verificado con pruebas específicas, no solo revisión de código).
- El sitio funciona correctamente en móvil y escritorio, y cumple WCAG 2.1 AA en flujos críticos (búsqueda, ficha de producto, checkout).
- Ningún producto queda publicado sin estado de revisión regulatoria 'aprobado'.
- Existe aviso de privacidad y mecanismo de consentimiento funcional antes de capturar datos personales.
- No existen secretos expuestos en el frontend.
- Existe respaldo y procedimiento de recuperación documentado con RPO/RTO definidos.